



STRATEGIC INTELLIGENCE

Volt Typhoon: Living-off-the-Land Pre-positioning in US Critical Infrastructure

Prepared by **Alex Mercer** · 2026-05-31

TLP:AMBER

STRATEGIC

PUBLISHED

SEC Energy

SEC Water and Wastewater Systems

TOP Nation-State Activity

TEC T1078 Valid Accounts

TEC T1059 Command and Scripting Interpreter

ACT G1017 Volt Typhoon

CAM Volt Typhoon CNI Pre-positioning

Key judgements

- **Volt Typhoon is pre-positioning, not collecting.** With high confidence, the group's intrusions into US energy, water and communications networks are intended to pre-stage disruptive effects in a future crisis rather than to conduct espionage. Observed activity is consistent with maintaining covert, long-term access.
- **Living-off-the-land is the defining tradecraft.** The actor relies almost exclusively on built-in Windows tooling (`wmic`, `netsh`, `netstat`, PowerShell) and valid accounts, leaving minimal malware on disk and blunting signature-based detection.
- **End-of-life edge devices are the launch point.** Compromised SOHO routers are chained into a covert proxy network so that command-and-control blends with legitimate regional traffic.

Assessment

Since at least mid-2023 the activity cluster tracked as **Volt Typhoon** (overlapping with Vanguard Panda) has run a deliberate campaign against US critical-infrastructure operators. The intrusions are notable less for their sophistication than for their **patience and discipline**: the operators prioritise staying hidden over moving fast.

Initial access and credential theft

Access is typically achieved by exploiting an internet-facing appliance, after which the actor authenticates using **valid accounts** (`T1078`). Operators then extract credentials from LSASS memory and the Active Directory database (`ntds.dit`) to enable quiet lateral movement toward operational-technology management hosts.

Defence evasion and persistence

The behavioural fingerprint is consistent across victims:

- **Discovery** — built-in `wmic`, `netsh` and `net group` surfaces as anomalous process lineage on domain controllers.
- **Credential access** — LSASS and `ntds.dit` dumps; visible in volume-shadow and handle-access alerts.
- **Command-and-control** — a SOHO-router proxy chain; egress to residential ASNs.

The hallmark is restraint: rather than deploying bespoke implants, operators reuse the victim's own administrative tooling, rotate through compromised credentials, and clean up artefacts as they go.

Outlook

We assess with moderate confidence that this pre-positioning will **broaden to additional sectors** over the next 12 months, with water and transportation operators at elevated risk given their thinner monitoring of OT management planes.

Recommendations

1. Hunt for anomalous `cmd.exe` / PowerShell parent-child chains on domain controllers and jump hosts.
2. Enforce phishing-resistant MFA on every externally reachable administrative interface.
3. Prioritise replacement of end-of-life edge appliances and segment OT management networks from corporate IT.

Sources

- [1] **CISA AA24-038A — PRC State-Sponsored Actors Compromise US CNI**
<https://www.cisa.gov/news-events/cybersecurity-advisories/aa24-038a>
 Joint advisory detailing living-off-the-land tradecraft against communications, energy, water and transportation sectors.

- [2] **Microsoft — Volt Typhoon targets US critical infrastructure**
<https://www.microsoft.com/security/blog/volt-typhoon>
 Initial public reporting on LOTL technique reliance and SOHO router proxy network.

- [3] **Internal telemetry review — DC process-lineage anomalies** [INT-2026-0412](#)
 Hunt across managed DCs surfaced anomalous wmic/netsh execution chains consistent with the advisory.

Attachments

- [1] [aa24-038a.pdf](#)

- [2] [volt-proxy-indicators.csv](#)